Replace and modernize legacy VPN architectures with a cloud-native Zscaler Zero Trust solution to reduce attack surface and lateral movement.

College name: Vidyasagar College of Arts and Science

College Code: bru30

Team ID : SWTID-2026-3194

Team Size : 5

Team Leader : TAMILMANI R V

Email: r.v.tamilmani2042@gmail.com

Team member : KATHIRESHAN S

Email: kathireshan231044@gmail.com

Team member : PREMKUMAR S

Email: premkumar23221041@gmail.com

Team member : GURUPRASATH M

Email: guruprasathm231028@gmail.com

Team member : DHARANI K

Email: dharanikanjana8148@gmail.com

Project details Title:

Replace and modernize legacy VPN architectures with a cloud-native Zscaler Zero Trust solution to reduce attack surface and lateral movement.

In response to the evolving threat landscape and the dissolution of the traditional network perimeter, this project initiates a fundamental shift in our security architecture. We will be decommissioning our legacy VPN infrastructure, which relies on an outdated castle-and-moat model that grants excessive network access and is vulnerable to lateral threat movement. To replace it, we are adopting a cloud-native, Zero Trust approach powered by Zscaler. This new architecture is built on the principle of "never trust, always verify," ensuring that users are connected to applications, not to the network. By making applications invisible to the internet and establishing direct, secure user-to-app connections, we will drastically reduce our attack surface. This modern solution eliminates the risk of lateral movement, as threats can no longer traverse a flat network. Furthermore, it provides a superior, high-performance experience for our hybrid workforce, decoupling security from data center backhauling. The transition to Zscaler will not only bolster our security posture but also enhance agility and reduce the operational overhead associated with managing legacy hardware. This initiative is a critical step in future-proofing our organization against sophisticated cyber threats.

Abstract:

This project details the strategic migration from a legacy Virtual Private Network (VPN) infrastructure to a cloud-native Zero Trust Network Access (ZTNA) solution provided by Zscaler. The primary driver for this initiative is the fundamental inadequacy of traditional VPNs in the modern threat landscape. Legacy architectures operate on a "connect first, verify later" model, granting users broad access to the corporate network and, consequently, creating a significant risk of lateral movement by malicious actors. This expansive attack surface, combined with the operational overhead of managing physical appliances and the poor user experience associated with hair-pinned traffic, renders the existing model both insecure and inefficient for today's hybrid workforce. The proposed solution leverages the Zscaler Zero Trust Exchange, a global, cloud native platform that shifts connectivity from a network-centric to an identity and application-

centric model. By making corporate applications invisible to the internet and establishing direct, secure connections between verified users and specific applications, the new architecture eliminates the concept of network-based privileges. This approach ensures that users connect to the applications they need, not the underlying network, thereby completely neutralizing the threat of lateral movement. Furthermore, it improves performance by steering traffic directly to Zscaler's edge nodes, optimizing the user experience regardless of their location. The expected outcomes of this modernization project are multifaceted. We anticipate a drastic reduction in the organization's attack surface and the complete elimination of lateral movement risks. This will be coupled with a simplified, scalable security posture managed from a unified cloud console, reducing operational costs and complexity. Ultimately, this transition will not only fortify our cyber defenses against sophisticated threats but also enable a secure, high performance, and agile work environment, future-proofing the organization's security architecture.

Use Case Scenarios

Scenario 1: Third-Party Vendor Access to Finance Application

An external auditor requires temporary access to the organization's finance application for auditing purposes. Instead of providing full VPN access, the **Zero Trust architecture** grants the vendor access only to the specific finance application through **application-level access control**.

Output:

- User identity verified through Identity Provider
- Time-limited access granted
- Connection restricted only to the finance application
- No access to internal network resources

Scenario 2: Research Assistant Access to High-Performance Computing Cluster

A research assistant needs SSH access to a computing cluster to run data analysis scripts. Using **Zero Trust Network Access**, the user is authenticated and allowed to connect only to the HPC server.

Output:

- User identity verified
- Protocol-specific access (SSH only)
- Secure micro-tunnel created to the target server
- Other network segments remain inaccessible

Scenario 3: Administrative Staff Access to Internal File Server

An administrative staff member working remotely needs to access internal files stored on the organization's file server. Instead of connecting through a traditional VPN, the system verifies the user's identity and device posture before granting application-specific access.

Output:

- Identity verification completed
- Device posture check passed
- Access granted only to the file server
- Data Loss Prevention policies applied

Scenario 4: IT Administrator Secure Access to Server Management Interfaces

An IT administrator requires remote access to manage internal servers through Remote Desktop Protocol (RDP). Using the Zero Trust model, the administrator is authenticated and granted access only to the required server management interface.

Output:

- Administrator identity verified
- Privileged access control enforced
- Secure encrypted micro-tunnel established
- Session monitoring and logging enabled

Scenario 5: Visiting Professor Access to Library Resources

A visiting professor from another institution needs temporary access to digital library archives hosted within the organization's internal network. The Zero Trust system provides limited and time-bound access to the specific library application.

Output:

- User identity verified
- Time-limited access granted
- Connection restricted to library application
- No access to other internal systems

Stage-1:

Title: - Replace and modernize legacy VPN architectures with a cloud-native Zscaler Zero Trust solution to reduce attack surface and lateral movement.

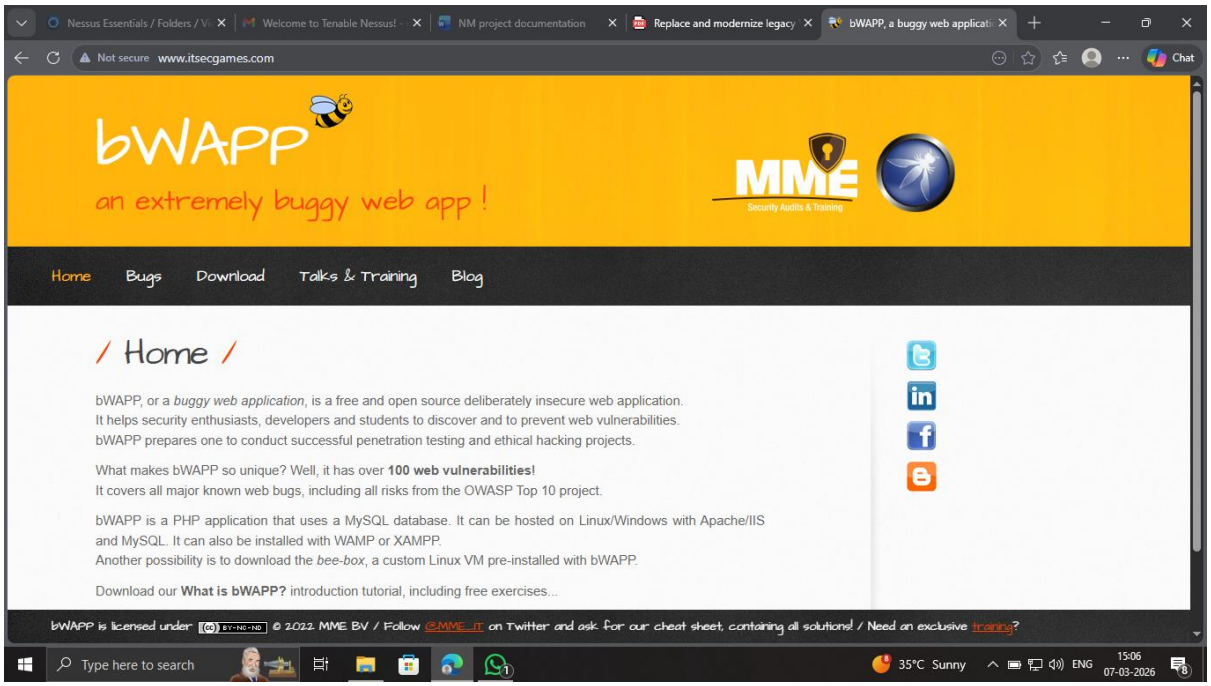
Web Application Vulnerability Testing

Overview

Stage-1 focuses on identifying common web application security vulnerabilities using a practice website. The purpose of this stage is to understand how attackers may exploit weaknesses in web applications and how these vulnerabilities can impact system security.

For this project, the practice website used for vulnerability analysis is:

http://www.itsecgames.com

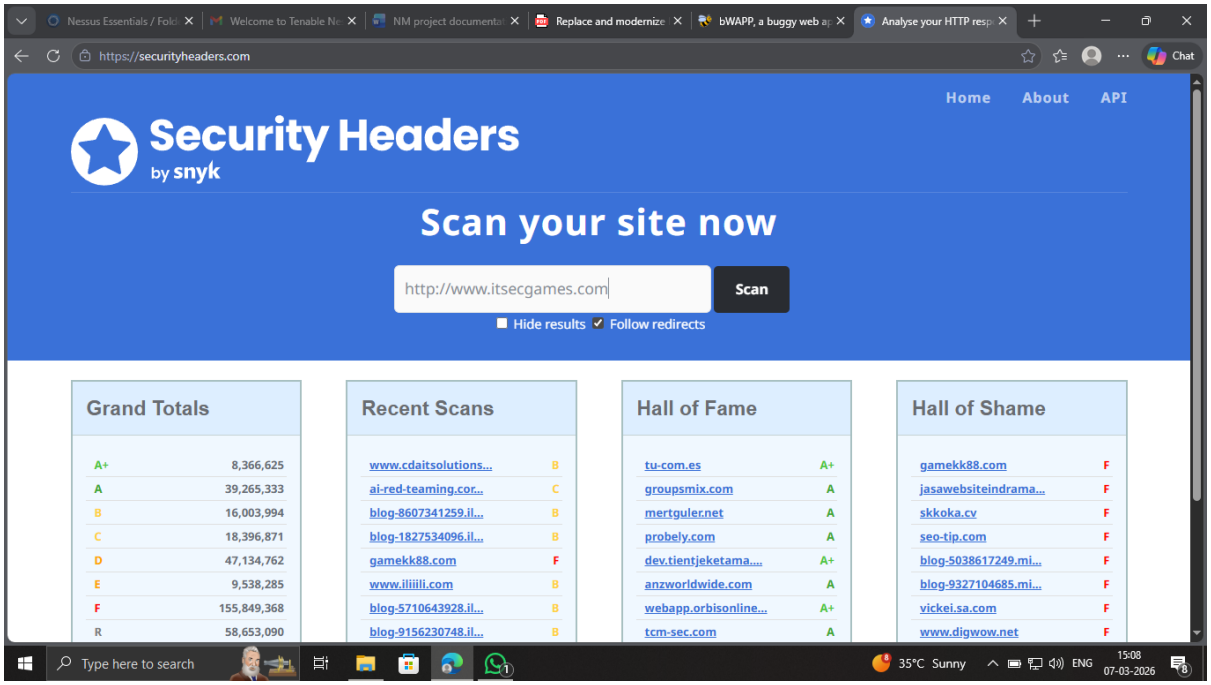


The vulnerabilities identified in this stage are based on the **OWASP Top 10**, which is a globally recognized list of the most critical web application security risks.

Vulnerability Details

1. Improper Sanitization of File Paths

CWE: CWE-284 – Improper Access Control



Description:

Improper sanitization of file paths occurs when a web application does not properly validate or restrict access to sensitive files or directories. Attackers may manipulate file paths to access restricted files on the server.

Business Impact:

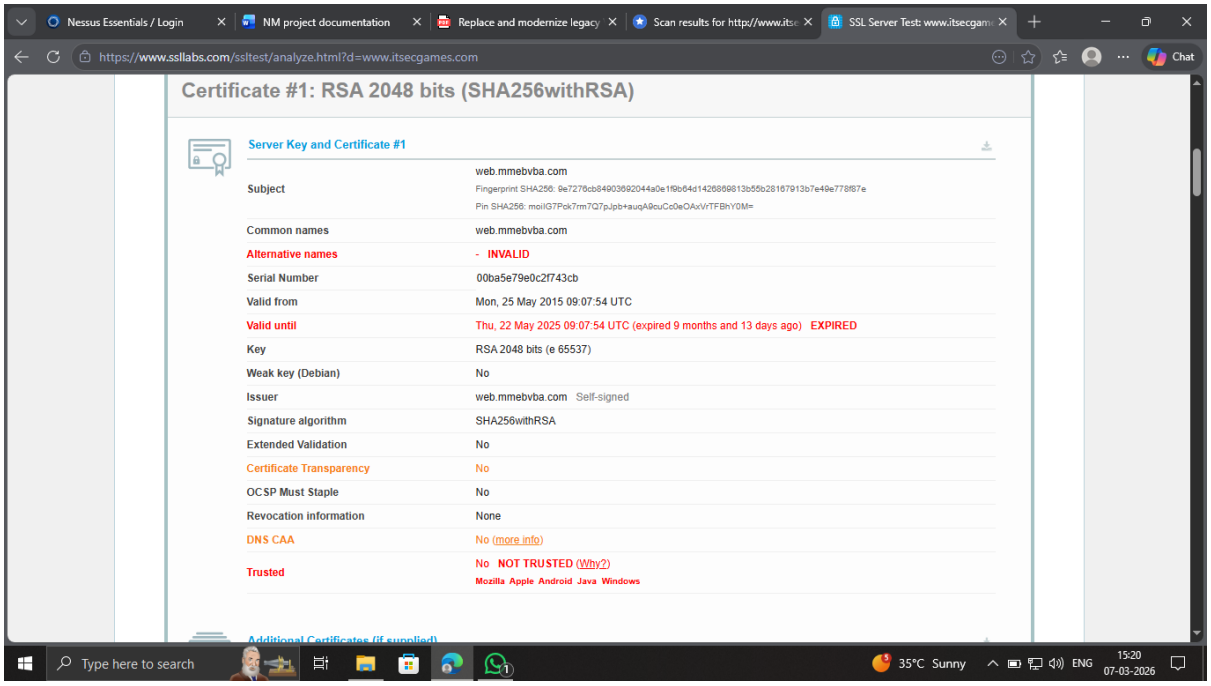
Attackers may gain unauthorized access to sensitive files, configuration data, or private information stored on the server.

Recommendation:

- Implement strict access control policies
- Restrict file system permissions
- Regularly audit file access permissions
- Apply security updates to the web application

2. Invalid Certificate

CWE: CWE-395 – Improper Certificate Validation



Description:

An invalid or improperly configured SSL certificate may allow attackers to impersonate trusted systems and intercept communications between users and the server.

Business Impact:

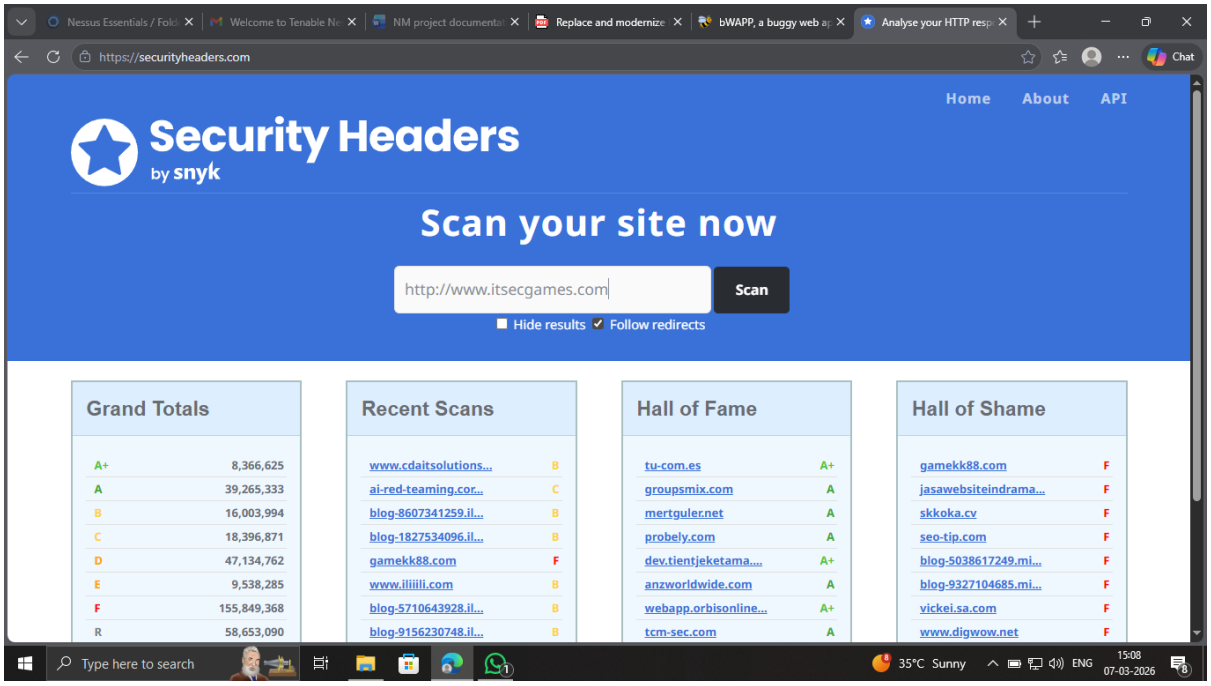
- Man-in-the-Middle attacks
- Data interception
- Unauthorized access to sensitive data

Recommendation:

- Use trusted certificate authorities
- Validate certificate chains
- Implement certificate pinning
- Regularly update security certificates

3. Missing X-Frame-Options Header

CWE: CWE-1021 – Improper Restriction of Rendered UI Layers



Description:

The absence of the **X-Frame-Options** HTTP header allows the web page to be embedded within an iframe on another website. This may lead to **clickjacking attacks** where users unknowingly interact with malicious content.

Business Impact:

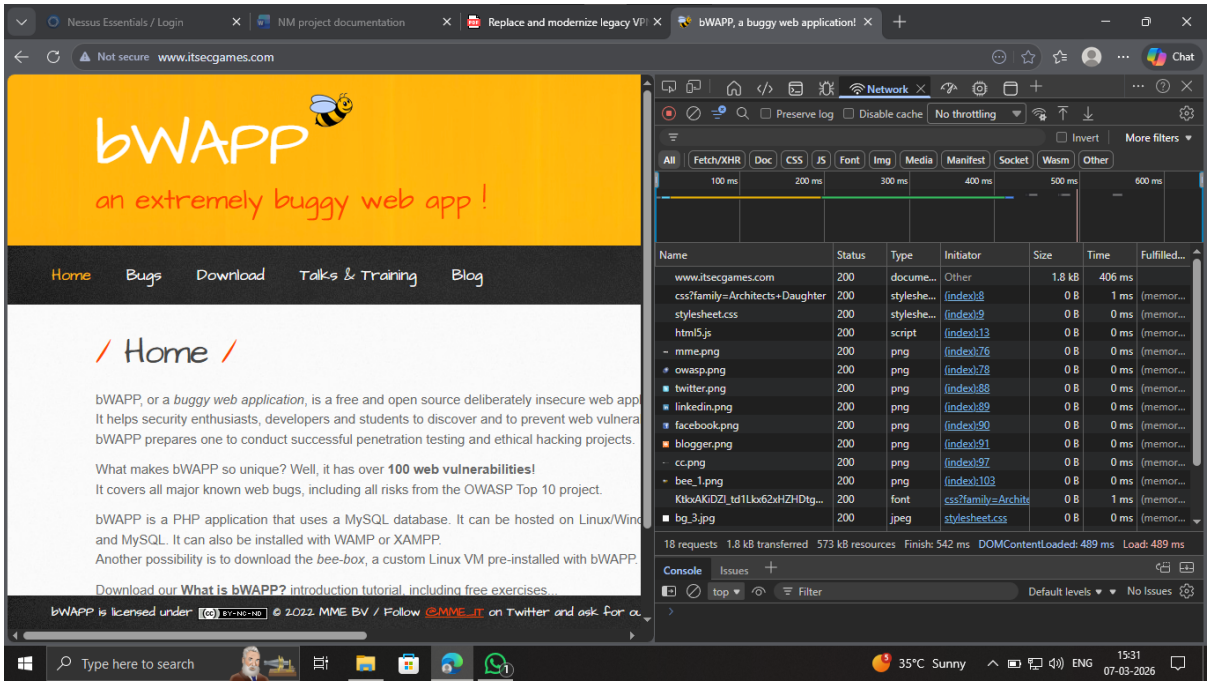
- Unauthorized user actions
- User interface manipulation
- Potential data theft

Recommendation:

- Implement the **X-Frame-Options header**
- Use Content Security Policy (CSP)
- Restrict iframe embedding

4. X-Content-Type Options Header Missing

CWE: CWE-918 – Server-Side Request Forgery



Description:

When the **X-Content-Type-Options** header is missing, browsers may attempt to guess the content type of files. This can allow attackers to manipulate how the browser interprets data.

Business Impact:

- Data exposure
- Security bypass
- Potential cross-site scripting attacks

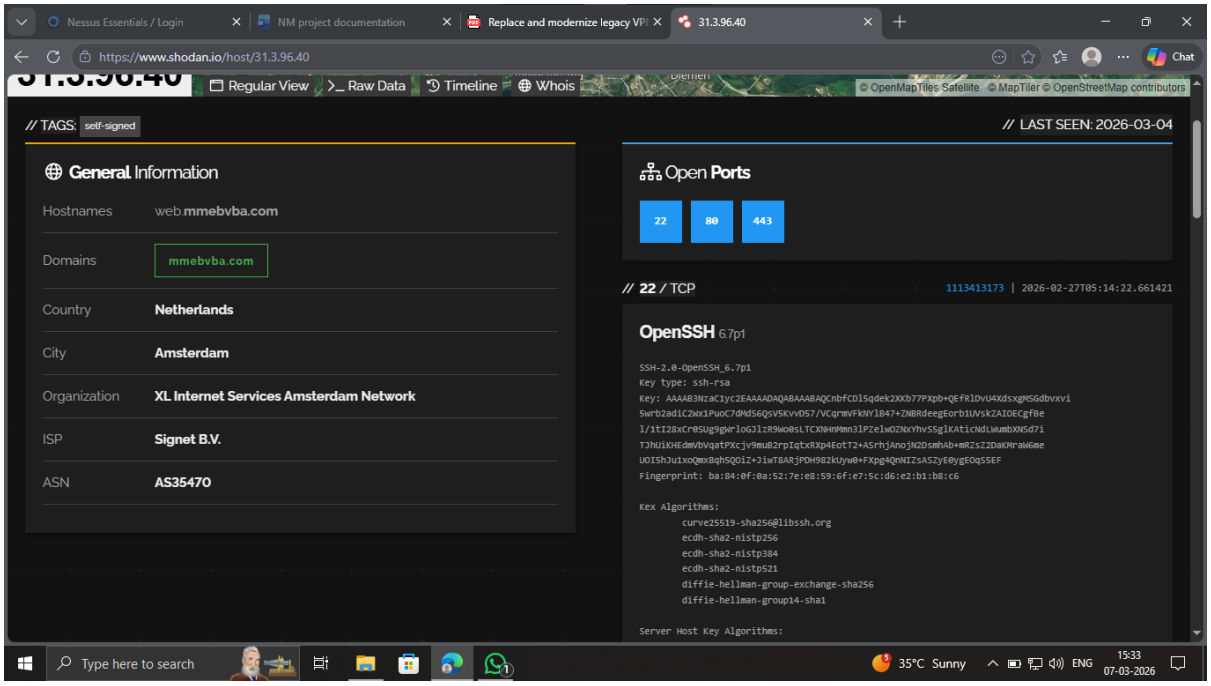
Recommendation:

Add the following security header in the server configuration:

```
X-Content-Type-Options: nosniff
```

5. Drupal Ajax API Shows JSONP Not Disabled

CWE: CWE-937 / CWE-1035 – Using Components with Known Vulnerabilities



Description:

Some Drupal API configurations allow JSONP requests by default. This may expose the application to vulnerabilities when outdated components or insecure configurations are used.

Business Impact:

- Exploitation of outdated components
- Remote code execution
- Unauthorized system access

Recommendation:

- Update Drupal components regularly
- Disable unused APIs
- Perform periodic vulnerability scanning

6. Drupal API Vulnerability (Improper Input Validation)

CWE: CWE-20 – Improper Input Validation

Description:

Improper validation of user input may allow attackers to inject malicious data into the application, potentially leading to SQL injection or command injection attacks.

Business Impact:

- Database compromise
- Data theft
- System manipulation

Recommendation:

- Validate and sanitize all user inputs
- Use parameterized queries
- Implement secure coding practices

7. Improper API Filtration (Cross-Site Scripting)

CWE: CWE-79 – Cross-Site Scripting (XSS)

Description:

Cross-Site Scripting occurs when a web application allows user input to be executed as a script in another user's browser.

Business Impact:

- Session hijacking
- Credential theft
- Website defacement

Recommendation:

- Encode user input properly
- Implement Content Security Policy
- Perform regular security testing

8. Denial of Service (DoS)

CWE: CWE-400 – Uncontrolled Resource Consumption

Description:

A Denial-of-Service attack attempts to overwhelm the server with excessive requests, causing the system to become unavailable to legitimate users.

Business Impact:

- Service interruption
- System downtime
- Loss of business operations

Recommendation:

- Implement rate limiting
- Use Web Application Firewalls (WAF)
- Monitor network traffic for unusual patterns

9. TLS Version 1.0 Protocol Detection

CWE: CWE-327 – Use of Broken or Risky Cryptographic Algorithm

Description:

TLS 1.0 is an outdated encryption protocol that contains known vulnerabilities.

Business Impact:

- Weak encryption
- Risk of data interception
- Non-compliance with modern security standards

Recommendation:

Disable TLS 1.0 and enable TLS 1.2 or TLS 1.3.

10. web.config File Information Disclosure

CWE: CWE-497 – Exposure of Sensitive Information

Description:

If the **web.config** file is accessible publicly, attackers may obtain sensitive configuration information including database credentials.

Business Impact:

- System compromise
- Data leakage
- Unauthorized system access

Recommendation:

- Restrict access to configuration files
- Encrypt sensitive data
- Implement strict access controls

Conclusion:

The vulnerability assessment of the practice website identified several common web application security weaknesses such as improper access control, outdated cryptographic protocols, cross-site scripting, and configuration exposure. Addressing these vulnerabilities is essential to protect sensitive data, prevent unauthorized access, and ensure the overall security of web applications

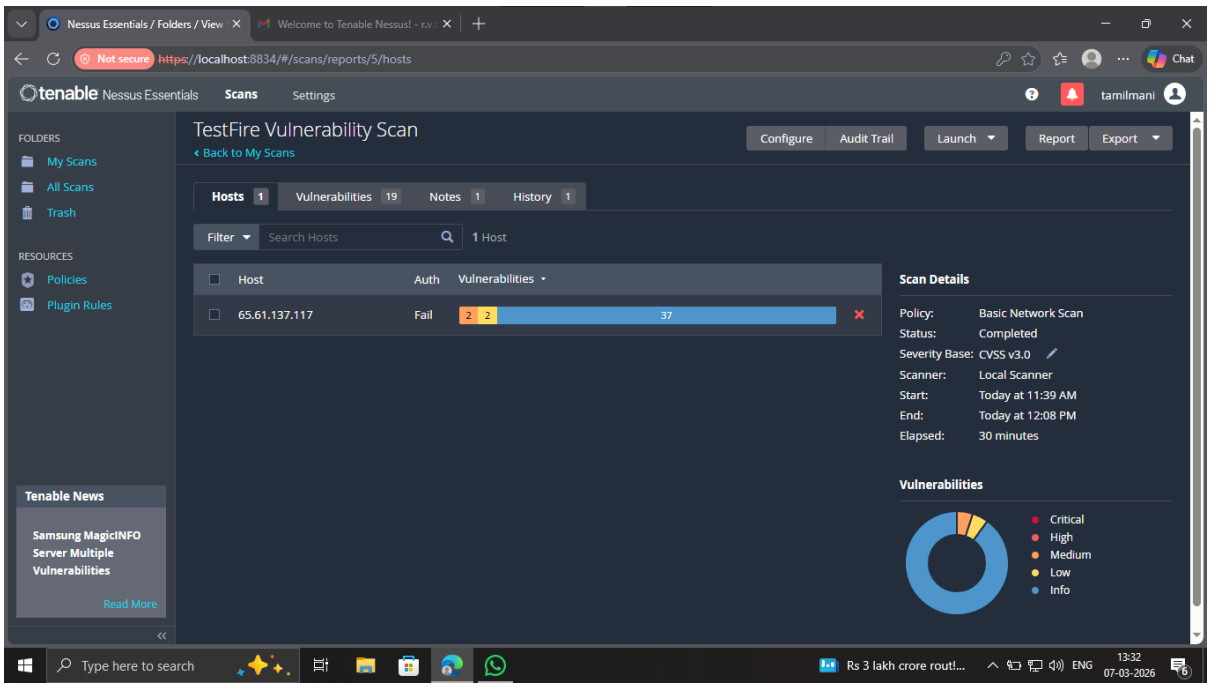
Stage-2

Title: - Replace and modernize legacy VPN architectures with a cloud-native Zscaler Zero Trust solution to reduce attack surface and lateral movement.

Vulnerability Scanning Using Nessus – Overview

In this stage, a vulnerability assessment was performed using **Nessus**, a widely used network security scanning tool developed by **Tenable**. Nessus is designed to identify security weaknesses in systems, networks, and web applications by sending various probes to the target host and analyzing its responses.

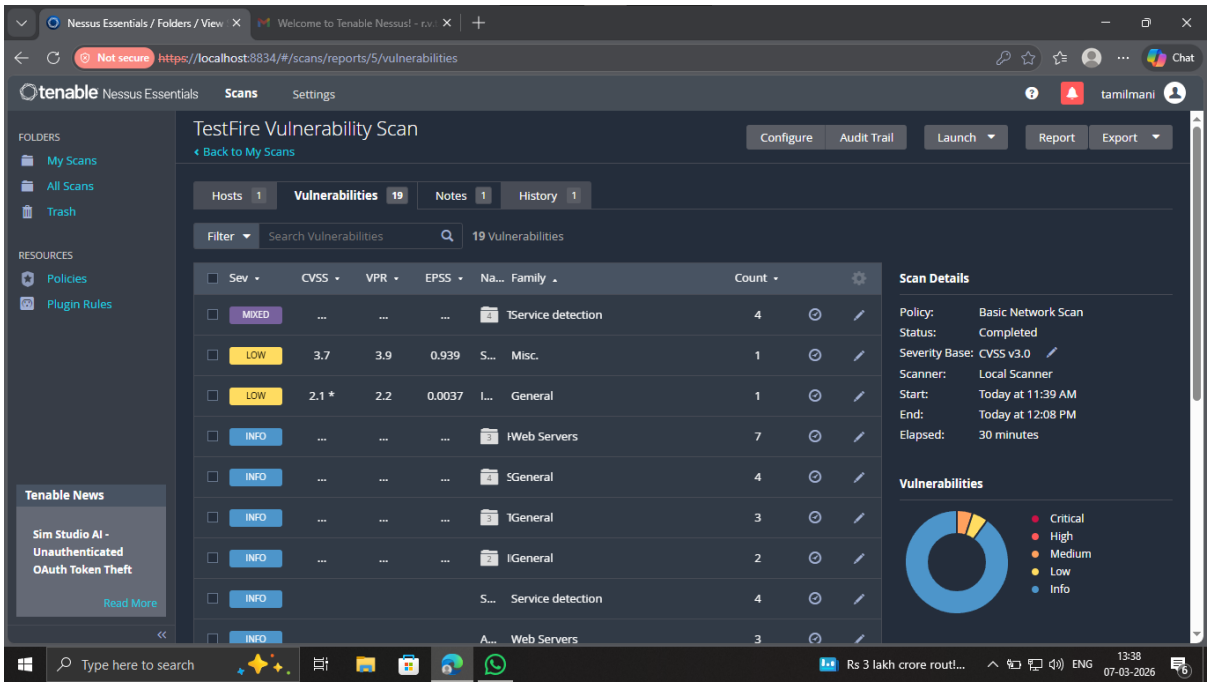
The scanner works through a **plugin-based architecture**, where each plugin is responsible for detecting a specific vulnerability such as outdated encryption protocols, insecure configurations, or exposed services. During the scanning process, Nessus first performs host discovery and service detection to determine the operating system and running services on the target system. After identifying these services, the scanner executes multiple vulnerability checks using its database of plugins.



For this project, the target system selected for the vulnerability assessment was:

```
Target Website : http://testfire.net
Target IP      : 65.61.137.117
```

The Nessus scan was configured using a **Basic Network Scan policy**, which performs a comprehensive assessment of the host by checking common network ports and identifying potential security vulnerabilities. After the scan was completed, Nessus generated a detailed report containing vulnerability findings categorized by severity levels such as **Medium, Low, and Informational**.



The results from the scan provided insight into several security issues present in the target system, including outdated TLS encryption protocols and server configuration information. These findings help security professionals understand potential weaknesses in the system and recommend appropriate remediation measures to improve overall security.

Nessus Essentials / Folders / View | Welcome to Tenable Nessus! - r.v.

Not secure https://localhost:8834/#/scans/reports/5/vulnerabilities/group/104743/157288

tenable Nessus Essentials | Scans | Settings | tamilmani

FOLDERS
- My Scans
- All Scans
- Trash

RESOURCES
- Policies
- Plugin Rules

Tenable News

CVE-2026-20127: Cisco Catalyst SD-WAN Controller/M...

Read More

TestFire Vulnerability Scan / Plugin #157288

‹ Back to Vulnerability Group

Configure | Audit Trail | Launch | Report | Export

Hosts 1 | Vulnerabilities 19 | Notes 1 | History 1

MEDIUM **TLS Version 1.1 Deprecated Protocol**

Description

The remote service accepts connections encrypted using TLS 1.1. TLS 1.1 lacks support for current and recommended cipher suites. Ciphers that support encryption before MAC computation, and authenticated encryption modes such as GCM cannot be used with TLS 1.1

As of March 31, 2020, Endpoints that are not enabled for TLS 1.2 and higher will no longer function properly with major web browsers and major vendors.

Solution

Enable support for TLS 1.2 and/or 1.3, and disable support for TLS 1.1.

See Also

https://datatracker.ietf.org/doc/html/rfc8996
http://www.nessus.org/u?c8ae820d

Output

```
TLSv1.1 is enabled and the server supports at least one cipher.
```

To see debug logs, please visit individual host

Port	Hosts
443 / tcp / www	65.61.137.117

Plugin Details

Severity:	Medium
ID:	157288
Version:	1.4
Type:	remote
Family:	Service detection
Published:	April 4, 2022
Modified:	May 14, 2024

Risk Information

Risk Factor: Medium
CVSS v3.0 Base Score: 6.5
CVSS v3.0 Vector:
CVSS:3.0/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:L/A:N
CVSS v2.0 Base Score: 6.1
CVSS v2.0 Vector:
CVSS2#AV:N/AC:H/Au:N/C:C/I:P/A:N

Vulnerability Information

Asset Inventory: True

Type here to search | 34°C Sunny | ENG | 13:41 07-03-2026

Nessus Essentials / Folders / View | Welcome to Tenable Nessus! - r.v.

Not secure https://localhost:8834/#/scans/reports/5/vulnerabilities/group/104743/104743

tenable Nessus Essentials | Scans | Settings | tamilmani

FOLDERS
- My Scans
- All Scans
- Trash

RESOURCES
- Policies
- Plugin Rules

Tenable News

Operation Epic Fury: Potential Iranian Cyber Count...

Read More

Hosts 1 | Vulnerabilities 19 | Notes 1 | History 1

MEDIUM **TLS Version 1.0 Protocol Detection**

Description

The remote service accepts connections encrypted using TLS 1.0. TLS 1.0 has a number of cryptographic design flaws. Modern implementations of TLS 1.0 mitigate these problems, but newer versions of TLS like 1.2 and 1.3 are designed against these flaws and should be used whenever possible.

As of March 31, 2020, Endpoints that aren't enabled for TLS 1.2 and higher will no longer function properly with major web browsers and major vendors.

PCI DSS v3.2 requires that TLS 1.0 be disabled entirely by June 30, 2018, except for POS POI terminals (and the SSL/TLS termination points to which they connect) that can be verified as not being susceptible to any known exploits.

Solution

Enable support for TLS 1.2 and 1.3, and disable support for TLS 1.0.

See Also

https://tools.ietf.org/html/draft-ietf-tls-oldversions-deprecate-00

Output

```
TLSv1 is enabled and the server supports at least one cipher.
```

To see debug logs, please visit individual host

Port	Hosts
443 / tcp / www	65.61.137.117

Plugin Details

Severity:	Medium
ID:	104743
Version:	1.10
Type:	remote
Family:	Service detection
Published:	November 22, 2017
Modified:	April 19, 2023

Risk Information

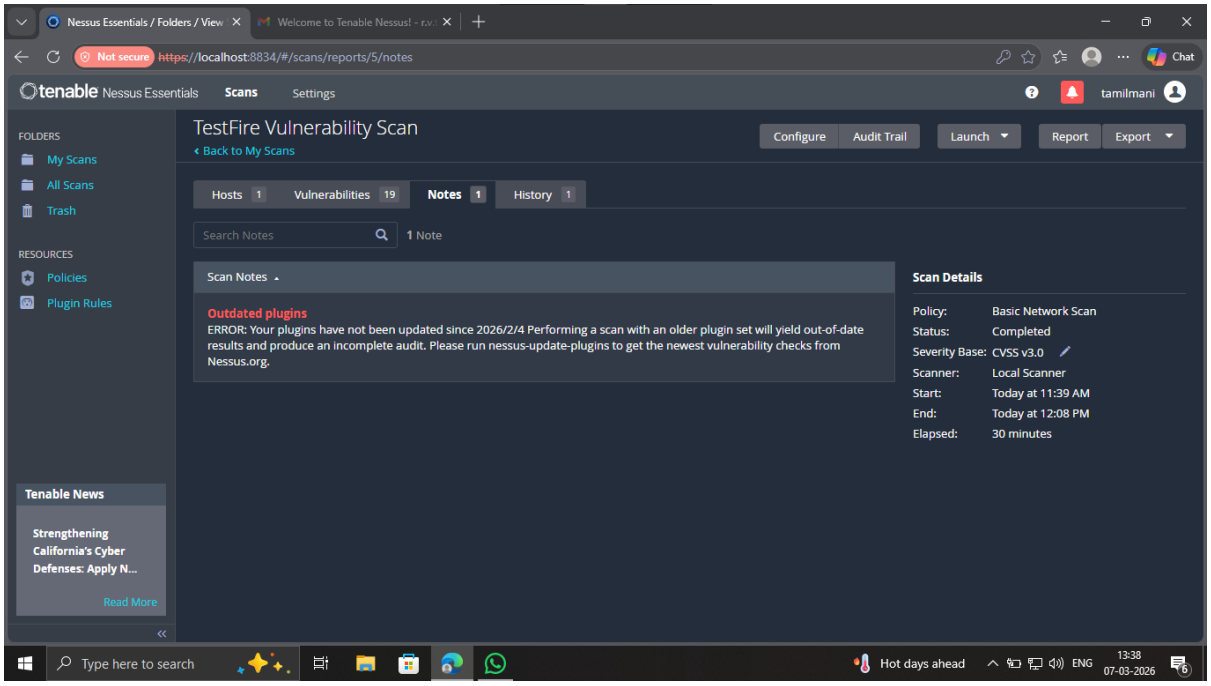
Risk Factor: Medium
CVSS v3.0 Base Score: 6.5
CVSS v3.0 Vector:
CVSS:3.0/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:L/A:N
CVSS v2.0 Base Score: 6.1
CVSS v2.0 Vector:
CVSS2#AV:N/AC:H/Au:N/C:C/I:P/A:N

Vulnerability Information

Asset Inventory: True

Reference Information

Type here to search | 34°C Sunny | ENG | 13:40 07-03-2026



List of vulnerability:-

s.no	Vulnerability name	Severity	plugins
1.	TLS Version 1.0 Protocol Detection	MEDIUM	104743
2.	TLS Version 1.1 Protocol Deprecated	MEDIUM	157288
3.	SSL/TLS Diffie-Hellman Modulus <= 1024 Bits (Logjam)	LOW	83875
4.	ICMP Timestamp Request Remote Date Disclosure	LOW	10114
5.	HTTP Server Type and Version	INFO	10107
6.	SSL Certificate Information	INFO	10863
7.	SSL/TLS Version Supported	INFO	56984

REPORT: -

1. TLS Version 1.0 Protocol Detection

Severity: Medium
Plugin ID: 104743
Port: 443

Description:

The remote server supports the TLS 1.0 encryption protocol. TLS 1.0 contains several known cryptographic weaknesses and is considered outdated according to

modern security standards. Many modern browsers and security frameworks no longer support this protocol due to its vulnerability to attacks.

Solution:
Disable TLS 1.0 on the server and enable more secure versions such as TLS 1.2 or TLS 1.3.

Business Impact:
Using outdated encryption protocols can allow attackers to intercept or manipulate sensitive communications between clients and servers. This may lead to data breaches, loss of sensitive information, and non-compliance with modern security standards.

2. TLS Version 1.1 Protocol Deprecated

Severity: Medium
Plugin ID: 157288
Port: 443

Description:
The remote server accepts connections using TLS 1.1 encryption protocol. TLS 1.1 does not support several modern cryptographic techniques and is considered deprecated by most security standards.

Solution:
Disable TLS 1.1 and enforce the use of stronger encryption protocols such as TLS 1.2 or TLS 1.3.

Business Impact:
Allowing deprecated encryption protocols increases the risk of attackers exploiting weaknesses in the encryption mechanism, potentially exposing sensitive data during transmission.

3. SSL/TLS Diffie-Hellman Modulus ≤ 1024 Bits (Logjam)

Severity: Low
Plugin ID: 83875
Port: 443

Description:
The server supports Diffie-Hellman key exchange parameters that use a modulus size of 1024 bits or less. Weak Diffie-Hellman parameters are susceptible to the **Logjam**

attack, which can allow attackers to downgrade encryption strength and decrypt secure communications.

Solution:
Configure the server to use Diffie-Hellman parameters of at least **2048 bits** or greater.

Business Impact:
Weak encryption parameters may allow attackers with sufficient resources to break encrypted communications, exposing confidential information and compromising system security.

4. ICMP Timestamp Request Remote Date Disclosure

Severity: Informational
Plugin ID: 10114
Port: 0

Description:
The remote host responds to ICMP timestamp requests. This allows external systems to determine the system time of the target host.

Solution:
Filter or block ICMP timestamp requests and replies at the firewall level.

Business Impact:
Although this vulnerability does not directly compromise the system, attackers may use this information during reconnaissance to assist in other types of attacks.

5. HTTP Server Type and Version

Severity: Informational
Plugin ID: 10107
Port: 443

Description:
The remote web server reveals information about the type and version of the HTTP server software being used.

Solution:
Configure the server to hide or minimize server banner information by modifying the server configuration.

Business Impact:
Exposing server type and version information can help attackers identify known vulnerabilities associated with the specific server software.

6. SSL Certificate Information

Severity: Informational
Plugin ID: 10863
Port: 443

Description:
The SSL certificate details of the remote host were detected. This information includes certificate issuer, validity period, and encryption details.

Solution:
Ensure that the SSL certificate is valid, issued by a trusted Certificate Authority, and regularly updated.

Business Impact:
Although this information itself is not harmful, attackers may use certificate details for reconnaissance or identifying misconfigured certificates.

7. SSL/TLS Version Supported

Severity: Informational
Plugin ID: 56984
Port: 443

Description:
The scan detected the SSL/TLS versions supported by the remote server. This helps determine which encryption protocols are enabled.

Solution:
Disable outdated SSL/TLS versions and allow only modern secure protocols such as TLS 1.2 and TLS 1.3.

Business Impact:
Supporting insecure SSL/TLS versions can expose the system to cryptographic attacks and compromise secure communications.

Stage-3

Title: - Replace and modernize legacy VPN architectures with a cloud-native Zscaler Zero Trust solution to reduce attack surface and lateral movement.

Overview

Traditional network security models rely heavily on **Virtual Private Networks (VPNs)** to allow remote users to access internal organizational resources. These legacy VPN architectures operate on a **perimeter-based security model**, often referred to as the *castle-and-moat approach*. In this model, once a user successfully authenticates to the VPN, they are granted broad access to the internal network.

However, this architecture is no longer suitable in modern environments where organizations support remote work, cloud services, and distributed applications. The

traditional VPN model introduces several security risks, including increased attack surface and the possibility of **lateral movement**, where attackers move across systems inside the network after gaining initial access.

Replace and modernize legacy VP...

To address these issues, organizations are shifting toward a **Zero Trust Network Access (ZTNA)** architecture using solutions such as **Zscaler Private Access**, which is part of the **Zscaler Zero Trust Exchange** platform.

Legacy VPN Architecture

Legacy VPN solutions establish an encrypted tunnel between remote users and the organization's internal network using VPN concentrators or gateway devices. Once authenticated, users are placed directly on the internal network and assigned an internal IP address.

This approach has several limitations:

1. **Over-permissioned access** – Users gain access to the entire network instead of only the applications they need.
2. **Expanded attack surface** – VPN gateways must expose ports to the public internet.
3. **Risk of lateral movement** – Attackers can move between internal systems if one device is compromised.
4. **Poor user experience** – Traffic is often routed through centralized data centers, causing latency.
5. **Operational overhead** – Organizations must maintain VPN hardware, apply patches, and manage capacity.

These limitations make legacy VPN systems vulnerable to modern cyber threats.

The Problem: Attack Surface and Lateral Movement

One of the biggest risks associated with traditional VPN architectures is the **expanded attack surface**. VPN gateways expose services to the internet, making them targets for attackers who perform port scanning, credential-stuffing attacks, or exploit vulnerabilities.

Another major issue is **lateral movement**. Once attackers gain access to the network through stolen credentials or compromised devices, they can scan the internal network and access other systems such as file servers, databases, and application servers.

This increases the likelihood of large-scale security breaches and data exfiltration.

Zero Trust Security Model

To overcome these challenges, organizations are adopting the **Zero Trust security model**, which follows the principle:

```
Never Trust, Always Verify
```

In a Zero Trust architecture:

- No user or device is automatically trusted.
- Every access request must be authenticated and authorized.
- Users are granted access only to specific applications rather than the entire network.

Zero Trust eliminates implicit trust within the network and significantly reduces security risks.

Zscaler Private Access (ZPA)

Zscaler Private Access (ZPA) is a cloud-native security solution that implements the Zero Trust model. Instead of connecting users to the network, ZPA connects users directly to the applications they need.

Key features of ZPA include:

1. Application-Level Access

Users connect directly to specific applications instead of the entire network.

2. Identity-Based Access Control

Access decisions are based on user identity, device posture, and security policies.

3. Micro-Segmentation

Each application is isolated from others, preventing attackers from moving laterally.

4. Invisible Applications

Internal applications are not exposed to the internet, reducing the attack surface.

5. Secure Micro-Tunnels

ZPA establishes encrypted micro-tunnels between users and applications, ensuring secure communication.

Benefits of the Zscaler Zero Trust Architecture

The adoption of Zscaler's Zero Trust architecture provides several advantages:

Reduced Attack Surface

Applications are hidden from the public internet, preventing direct attacks.

Prevention of Lateral Movement

Users can access only the specific applications they are authorized to use.

Improved Performance

Traffic is routed through Zscaler's global cloud infrastructure rather than centralized data centers.

Simplified IT Operations

Organizations no longer need to maintain complex VPN hardware.

Enhanced Security Posture

Continuous authentication and authorization reduce the risk of unauthorized access.

Conclusion

Stage-1: Web Application Vulnerability Testing

In Stage-1, web application vulnerability testing was performed using a practice website to identify common security weaknesses. The vulnerabilities were analyzed based on the OWASP Top 10 security risks. Several issues such as improper input validation, missing security headers, cross-site scripting risks, and weak encryption protocols were identified. This stage helped in understanding how attackers exploit web application weaknesses and how proper security configurations and secure coding practices can help prevent these vulnerabilities.

Stage-2: Vulnerability Scanning Using Nessus

In Stage-2, a vulnerability scan was conducted using the Nessus vulnerability scanner. The tool was used to scan the target website and identify security issues related to network services and system configurations. The scan results revealed vulnerabilities such as outdated TLS encryption protocols, weak Diffie-Hellman parameters, and server information disclosure. This stage helped in understanding how automated vulnerability scanning tools assist security professionals in detecting potential security threats and improving system security.

Stage-3: Zero Trust Architecture Using Zscaler

In Stage-3, the project explored the concept of replacing traditional VPN architectures with a Zero Trust security model using Zscaler. Unlike legacy VPN systems that provide broad network access after authentication, Zero Trust follows the principle of “Never Trust, Always Verify.” Users are granted access only to specific applications instead of the entire network. This approach significantly reduces the attack surface and prevents lateral movement within the network. Implementing

Zscaler's Zero Trust architecture improves security, enhances access control, and provides a more scalable and efficient solution for modern organizations.

Future Scope

Stage-1: Future Scope of Web Application Testing

In the future, web application testing can be enhanced by integrating automated security testing tools and continuous vulnerability monitoring systems. Advanced security techniques such as penetration testing, automated vulnerability scanning, and secure coding practices can be implemented to identify vulnerabilities more efficiently. Organizations can also adopt Web Application Firewalls (WAF) and real-time monitoring systems to protect web applications from emerging cyber threats.

Stage-2: Future Scope of Vulnerability Scanning Process

The vulnerability scanning process can be improved by implementing continuous security assessments and automated scanning tools within the network infrastructure. Future improvements may include integrating vulnerability scanners with security monitoring systems such as SIEM platforms to provide real-time threat detection. Regular vulnerability scanning and patch management processes can help organizations maintain a stronger security posture and reduce the risk of cyber attacks.

Stage-3: Future Scope of SOC / SIEM Implementation

The future scope of SOC and SIEM implementation involves deploying advanced security monitoring systems capable of analyzing large volumes of security data in real time. By integrating threat intelligence platforms, machine learning techniques, and automated incident response mechanisms, organizations can significantly improve their ability to detect and respond to cyber threats. Implementing SOC infrastructure in educational institutions and enterprises can help create a proactive cybersecurity environment and strengthen overall network security.

Topics Explored

- Web Application Security
- OWASP Top 10 Vulnerabilities
- Vulnerability Assessment and Risk Analysis
- Network Vulnerability Scanning

- Encryption Protocol Security (TLS/SSL)
- Zero Trust Security Model
- Legacy VPN Security Risks
- Security Operations Center (SOC)
- Security Information and Event Management (SIEM)
- Threat Intelligence and Incident Response

Tools Explored

- Nessus Vulnerability Scanner
- SecurityHeaders Scanner
- SSL Labs Security Testing Tool
- Browser Developer Tools (Network & Security Inspection)
- Zscaler Zero Trust Platform
- SIEM Tools (Conceptual Understanding)
- QRadar Security Intelligence Platform
- Network Monitoring and Security Analysis Tools